



r-tec Cyber Security GmbH an **accompio** Company

PENETRATIONSTEST

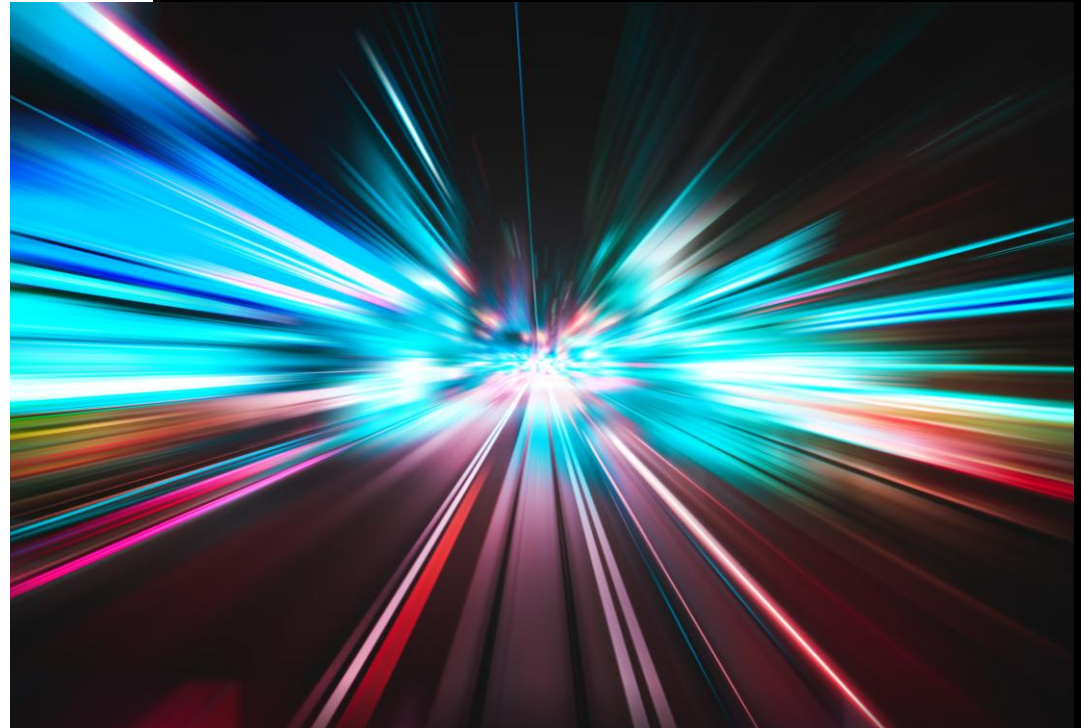
Einstieg und Einblick in die Welt des beruflichen Hackings

Nico Viakowski
Security Consultant



an **accompio** company

WHOAMI



WHOAMI

- ▶ Security Consultant
 - ▶ ~5 Jahre Erfahrung mit Penetrationstests
 - ▶ Bei r-tec im Offensive Services Team
 - ▶ Durchführung von Penetrationstests und Awareness Kampagnen
 - ▶ <https://github.com/vianic>



WAS STECKT HINTER EINEM PENETRATIONSTEST?

Tübix 2026



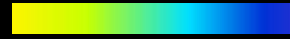
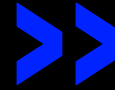
AGENDA

- ▶ Was ist ein Penetrationstest?
 - ▶ Penetrationstest vs. Angriff
- ▶ Was sagt das Gesetz dazu?
- ▶ Phasen eines Penetrationstest
- ▶ Shady Business in Farben
- ▶ Welche Arten von Penetrationstests gibt es?
- ▶ Wie werde ich Penetrationstester?

Was ist ein Penetrationstest?

Ein Penetrationstest ist ein beauftragter, kontrollierter Angriff auf ein System, eine Anwendung und / oder ein Unternehmen, um Sicherheitslücken zu identifizieren.





**Wenn der
Kunde
glücklich ist,
bin ich immer
nicht so
glücklich.**

Fabian Mosch

Pentest

Schriftliche Beauftragung liegt vor

Ziel:
Verbesserung der Sicherheit

Scope: Klar definiert

Ablauf: Dokumentiert & koordiniert

Legal

vs.

Realer Angriff

Unbefugte Zugriffe auf Ressourcen

Ziel:
Eigennutzen, -bereicherung

Scope: Unbegrenzt

Ablauf: Verdeckt & destruktiv

Strafbar

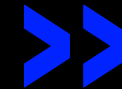
WAS SAGT DAS GESETZ DAZU?

Tübix 2026



WAS SAGT DAS GESETZ DAZU?

- ▶ Relevante Paragraphen im Strafgesetzbuch (StGB) bezüglich Hacking
 - ▶ §202a - *Ausspähen von Daten* → bis zu 3 Jahre
 - ▶ §202b - *Abfangen von Daten* → bis zu 2 Jahre
 - ▶ §202c - *Vorbereiten des Ausspähens und Abfangens von Daten* → bis zu 2 Jahre
 - ▶ §303a – *Datenveränderung* → bis zu 2 Jahre
 - ▶ §303b – *Computersabotage* → bis zu 5 Jahre



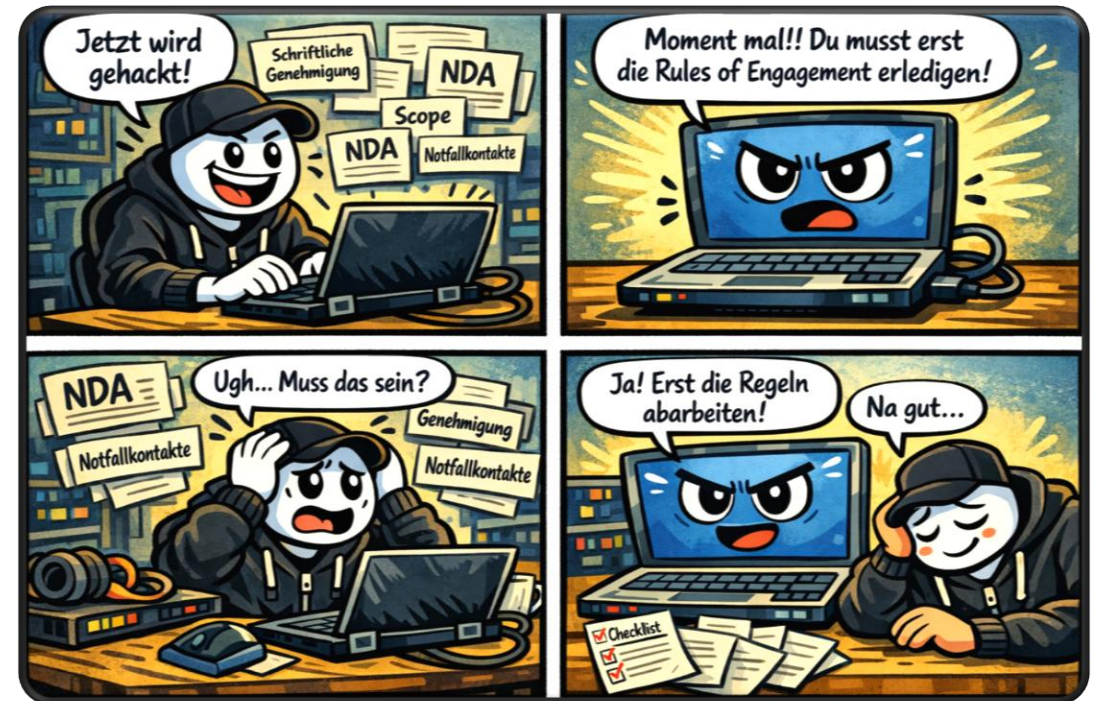
**Ohne eine schriftliche
Genehmigung des
Eigentümers ist jeder Pentest
strafbar -
auch auf Systeme der
eigenen Firma**

WAS BENÖTIGEN WIR FÜR EINEN PENETRATIONSTEST?

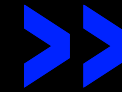
- 1 Schriftliche Genehmigung (Einverständniserklärung)
- 2 Klar definierter Scope (IP-Adressen, Systeme, Zeiten)
- 3 Notfallkontakte
- 4 Datenschutz & Vertraulichkeit (NDA)
- 5 Umgang mit Drittanbieter-Systemen
- 6 Definition des Eskalationsweg / Reportweg



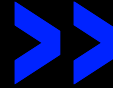
Rules of Engagement



STORYTIME



Do we have a ladies /
gentlemen agreement?

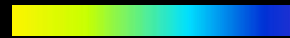
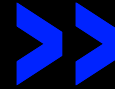


Danke für den Hinweis, Anzeige ist raus

Eine IT-Forscherin hat der CDU eine Schwachstelle in ihrer Connect-App gemeldet. Und die Partei? Zeigt sie an. Der Fall zeigt das rechtliche Dilemma ethischer Hacker.

**"Leider hat die CDU damit
das implizite Ladies-and-
Gentlemen-Agreement der
responsible disclosure
einseitig aufgekündigt"**

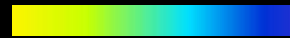
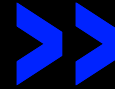
Chaos Computer Club



Datenleck: Anzeige gegen IT-Experte kam von Modern Solution

Der Softwareanbieter hat laut Ermittlungsakten Anzeige gegen den Programmierer erstattet, der auf die Gefährdung der Daten von 700.000 Kunden hingewiesen hatte.

<https://www.heise.de/news/Datenleck-Anzeige-gegen-IT-Experte-kam-von-Modern-Solution-6254839.html>



Besonders zynisch ist, dass Screenshots, die den Zugang belegten, vor Gericht als Beweis für die Strafbarkeit gewertet wurden. Genau diese Dokumentation ist aber Voraussetzung für eine ernstzunehmende Meldung an Hersteller oder Behörden. Ohne Belege nimmt niemand eine Schwachstelle ernst. Mit Belegen macht man sich in Deutschland strafbar.

<https://www.kuketz-blog.de/modern-solution-bundesverfassungsgericht-bestaetigt-wegsehen-ist-sicherer-als-aufdecken/>

PHASEN EINES PENETRATIONSTEST

Tübix 2026

PHASEN EINES PENETRATIONSTESTS



- ▶ Termine
- ▶ Rahmenbedingungen

- ▶ Informationsbeschaffung
- ▶ Port Scanning
- ▶ Fingerprinting

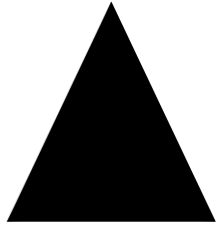
- ▶ Identifikation von Schwachstellen
- ▶ Automatische und manuelle Ausnutzung der Schwachstellen

- ▶ Auswertung der Ergebnisse
- ▶ Bericht und Präsentation
- ▶ Risikobewertung
- ▶ Maßnahmenplan

SHADY BUSINESS IN FARBEN

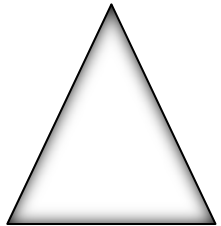
Tübix 2026

SHADY BUSINESS IN FARBEN



Black Hat

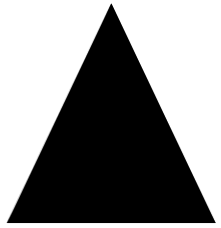
- ▶ Ohne Autorisierung
- ▶ Persönlicher Vorteil
- ▶ Aktive Ausnutzung von Schwachstellen



White Hat

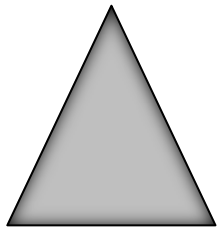
-
- ▶ Mit Autorisierung
 - ▶ Sicherheitsverbesserung
 - ▶ Verantwortungsvolle Offenlegung (Responsible Disclosure)

SHADY BUSINESS IN FARBEN



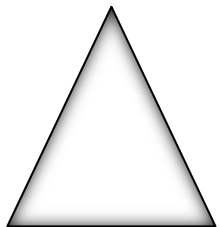
Black Box

- ▶ Keine Infos



Grey Box

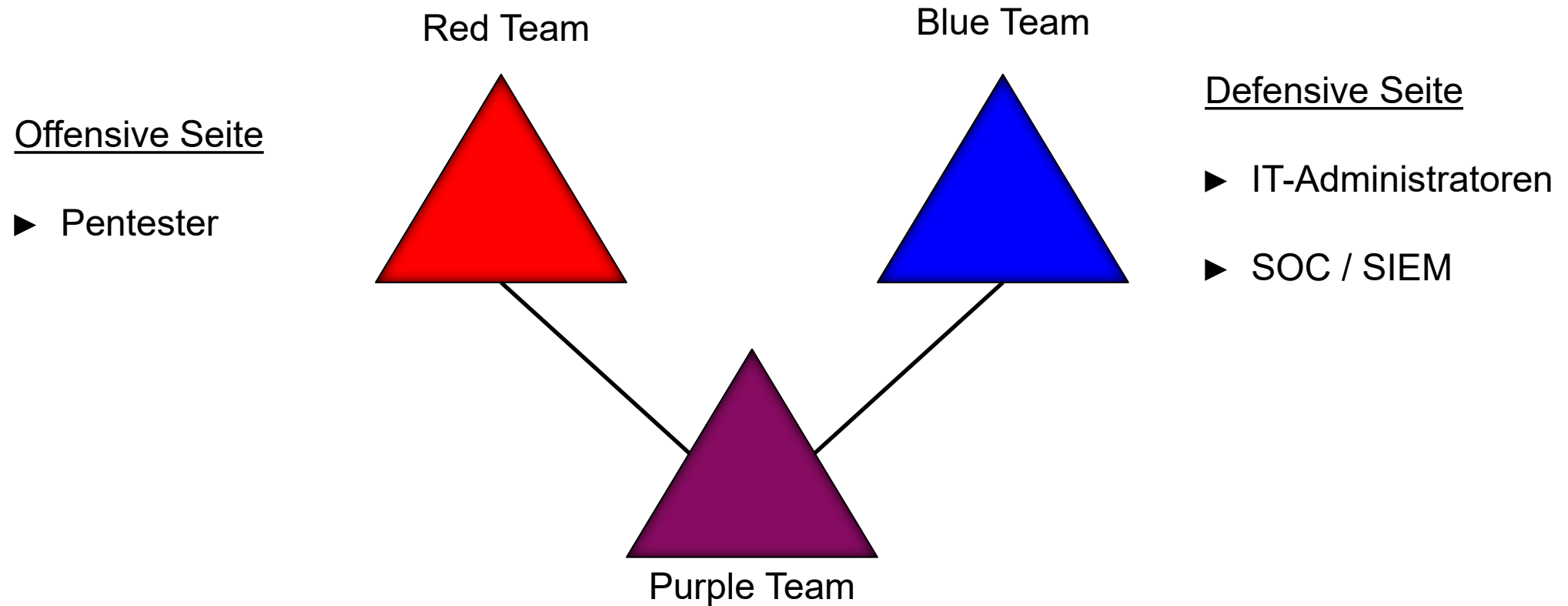
- ▶ Einzelne Informationen
 - ▶ IP-Adressen
 - ▶ URL
 - ▶ Zugangsdaten



White Box

- ▶ Sämtliche Technologie-Informationen bereitgestellt
 - ▶ Architektur
 - ▶ Versionsstände
 - ▶ Benutzer
 - ▶ Volle Zugriffe

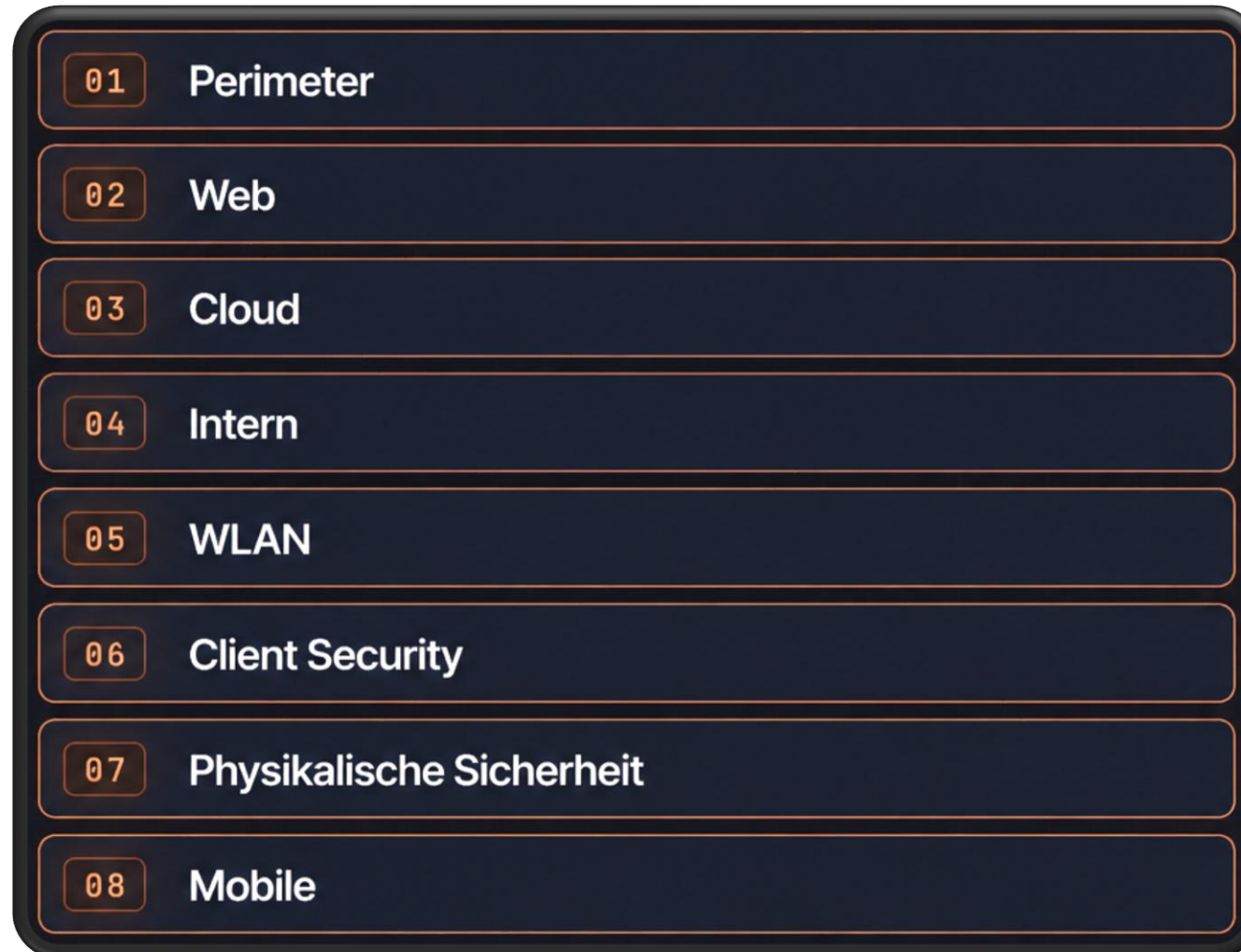
SHADY BUSINESS IN FARBEN



WELCHE ARTEN VON PENETRATIONSTESTS GIBT ES?



WELCHE ARTEN VON PENETRATIONSTESTS GIBT ES?

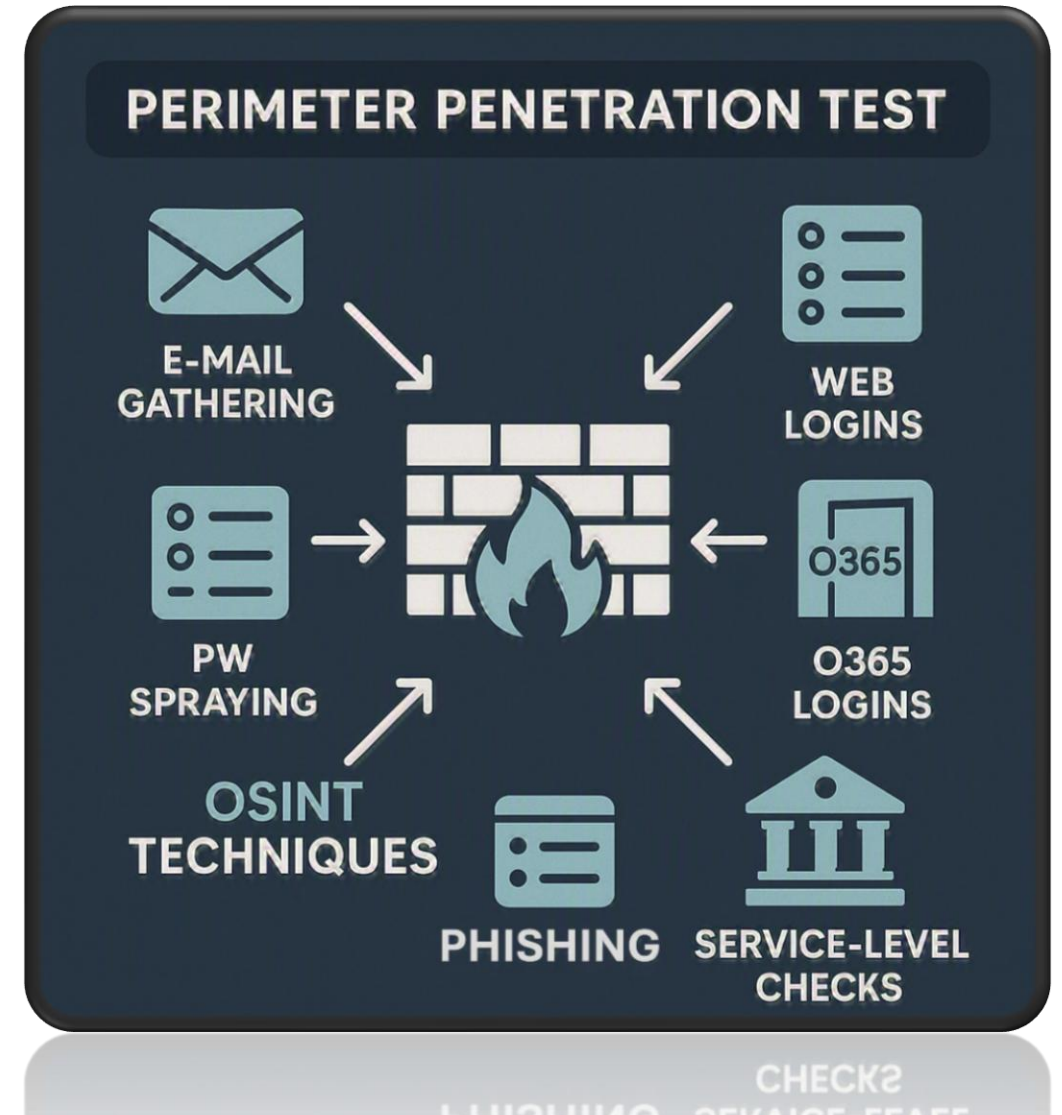
- 
- 01 Perimeter
 - 02 Web
 - 03 Cloud
 - 04 Intern
 - 05 WLAN
 - 06 Client Security
 - 07 Physikalische Sicherheit
 - 08 Mobile

VULNERABILITY SCAN

- ▶ Überprüft primär Patch- / Update-Management sowie Low-Hanging-Fruits
- ▶ Kann dadurch signifikante Schwachstellen aufdecken
- ▶ Keine manuelle Ausnutzung identifizierter Schwachstellen
- ▶ Häufiger Fehlschläge, wenn keine Standard-Konfiguration
- ▶ Dauer: Stunden
- ▶ Geringe Tiefe

PERIMETER

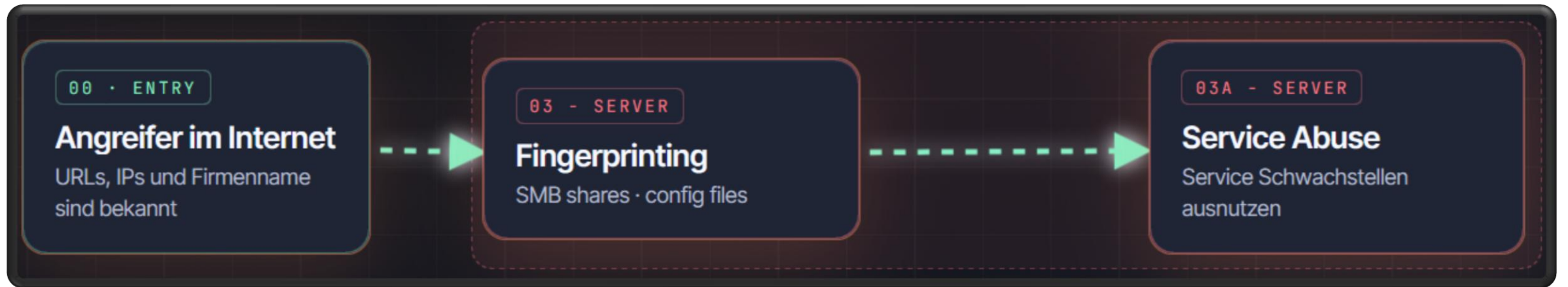
- ▶ Exponierte Systeme im Internet
- ▶ Phishing
- ▶ Ziel / Worst-Case:
 - ▶ Kompromittierung führt ins Unternehmensnetzwerk
 - ▶ Übernahme von Webservern



PERIMETER



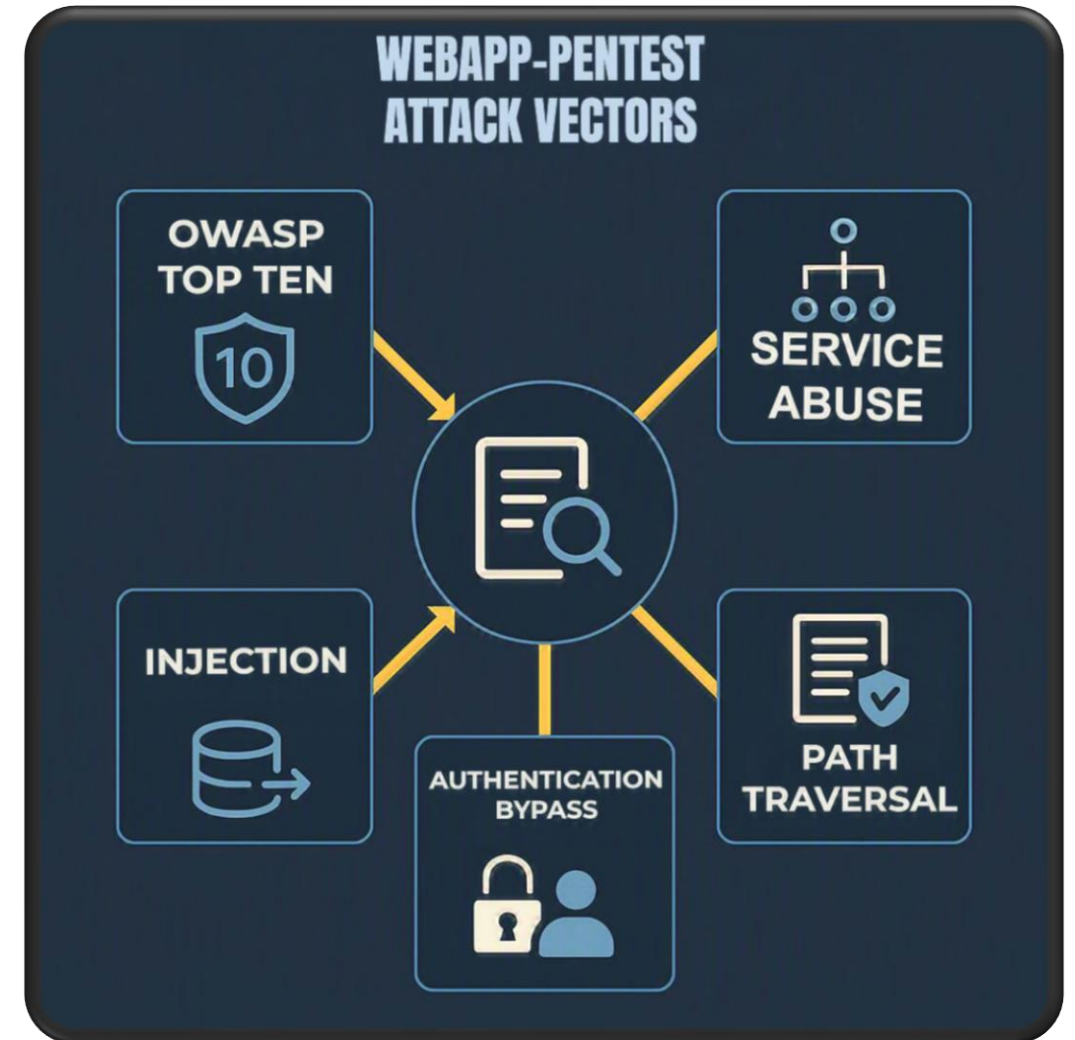
PERIMETER





WEBANWENDUNGEN

- ▶ Extern und intern erreichbare Webanwendungen
- ▶ Darunterliegende Webserver
- ▶ Ziel / Worst-Case:
 - ▶ Kompromittierung des Servers
 - ▶ Einsicht in fremde Daten
 - ▶ Übernahme der Webanwendung



Gehaltsdaten - Max Mustermann

← → <https://portal.beispiel-firma.de/gehaltsdaten?id=7f3a9b2c4d8e6f91> ☆ M

 **MusterFirma Portal**

Angemeldet als: hr@musterfirma.de Abmelden

Gehaltsdaten_Max_Mustermann.pdf

1 / 1 100%

Download Print

Gehaltsabrechnung

Arbeitsnehmer
Max Mustermann
Musterweg 12
12345 Musterstadt

MusterFirma GmbH
Musterstraße 1
12345 Musterstadt

Personalnummer: 10025
Abrechnungsmonat: Mai 2024
Abrechnungsdatum: 31.05.2024

Bruttoentgelt	
Bezeichnung	Betrag (EUR)
Grundgehalt	4.200,00
Funktionszulage	800,00
Fahrtkostenzuschuss	100,00
Bruttogesamt	5.100,00

Abzüge	
Bezeichnung	Betrag (EUR)
Lohnsteuer	890,25
Solidaritätszuschlag	48,97
Kirchensteuer	80,12
Rentenversicherung	474,30
Krankenversicherung	408,00
Pflegeversicherung	97,75
Arbeitslosenversicherung	61,20
Abzüge gesamt	2.060,59

Nettoauszahlung **3.039,41**

Diese Abrechnung wurde elektronisch erstellt und ist ohne Unterschrift gültig.

Gehaltsdaten - Sabina Hausman

+

https://portal.beispiel-firma.de/gehaltsdaten?id=9c4e28b7a1d2f497

☆ M

MusterFirma Portal

Angemeldet als: hr@musterfirma.de

Abmelden

Gehaltsdaten_Sabina_Hausmann.pdf

1 / 1 | 100%



Gehaltsabrechnung

Arbeitnehmerin
Sabina Hausmann
Lindenweg 7
12345 Musterstadt

Personalnummer: 10037
Abrechnungsmonat: Juni 2024
Abrechnungsdatum: 30.06.2024

Bruttoentgelt	
Bezeichnung	Betrag (EUR)
Grundgehalt	4.600,00
Funktionszulage	900,00
Fahrtkostenzuschuss	120,00
Bruttogesamt	5.620,00

Abzüge	
Bezeichnung	Betrag (EUR)
Lohnsteuer	1.012,35
Solidaritätszuschlag	55,68
Kirchensteuer	90,91
Rentenversicherung	521,22
Krankenversicherung	452,30
Pflegeversicherung	104,37
Arbeitslosenversicherung	70,73
Abzüge gesamt	2.307,56

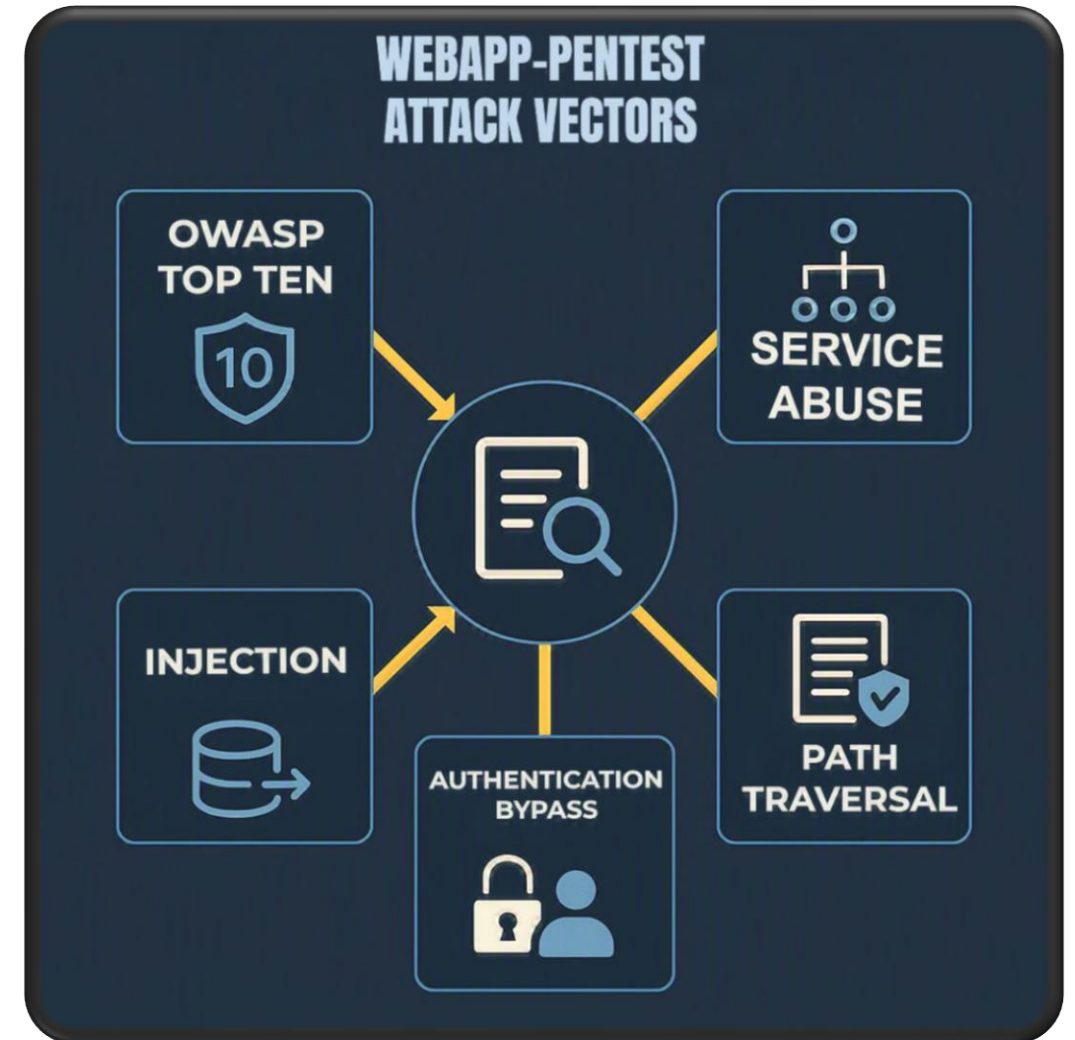
Nettoauszahlung

3.312,44

Diese Abrechnung wurde elektronisch erstellt und ist ohne Unterschrift gültig.

WEBANWENDUNGEN

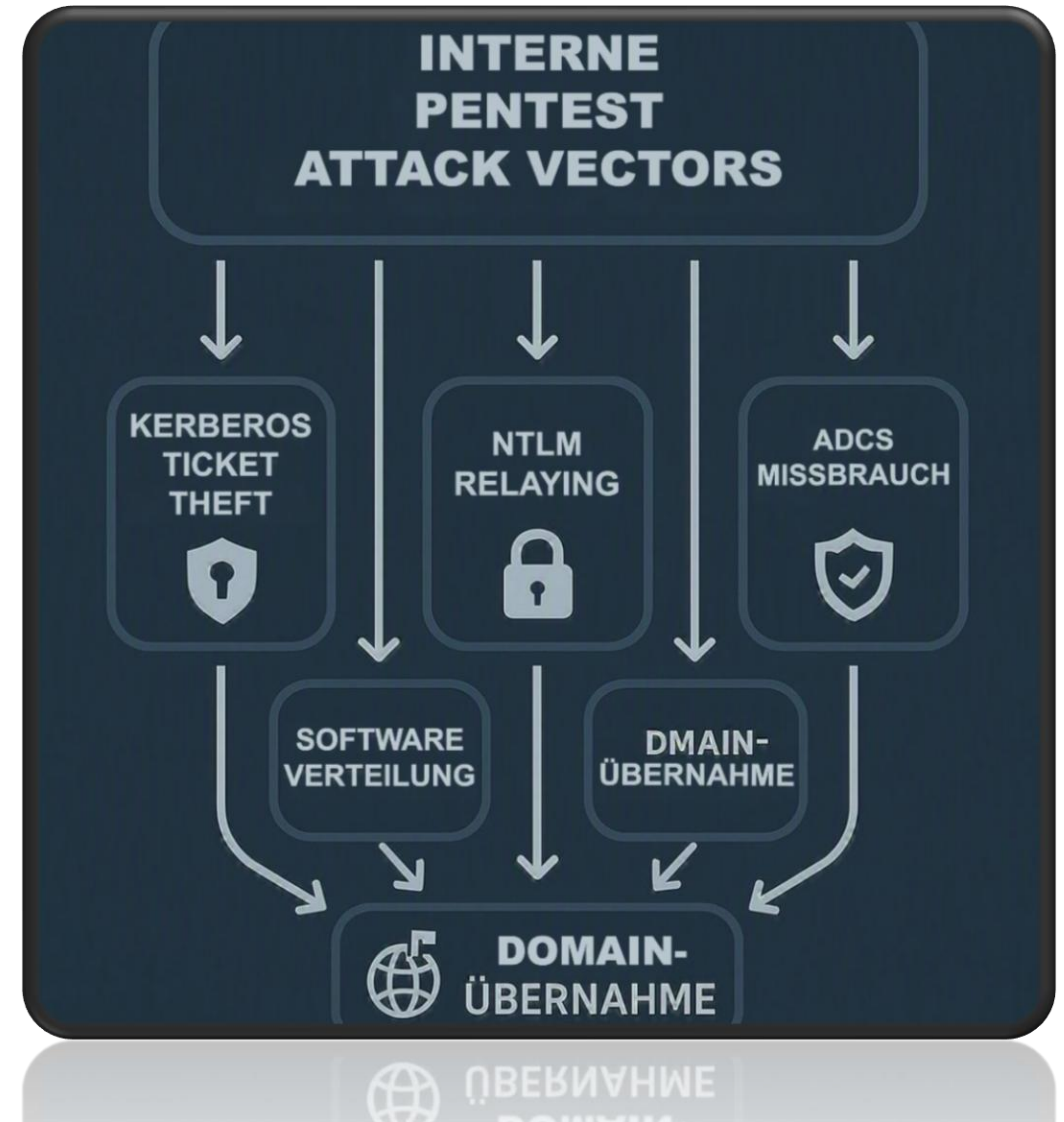
- ▶ Extern und intern erreichbare Webanwendungen
- ▶ Darunterliegende Webserver
- ▶ Ziel / Worst-Case:
 - ▶ Kompromittierung des Servers
 - ▶ Einsicht in fremde Daten
 - ▶ Übernahme der Webanwendung



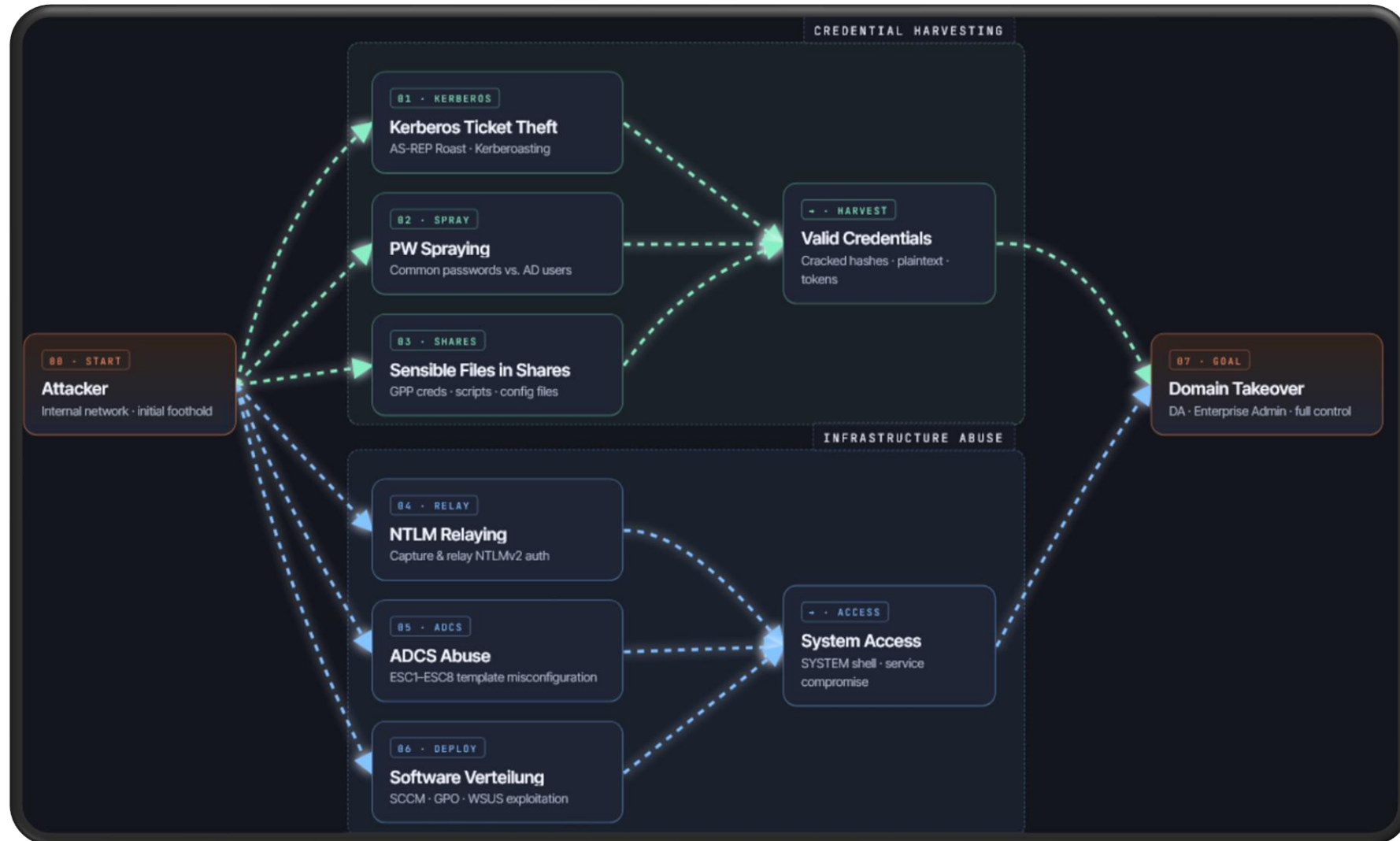


INTERN

- ▶ Unternehmensnetzwerk
- ▶ Backup Systeme
- ▶ Ziel / Worst-Case:
 - ▶ Kompromittierung von Servern / Domäne
 - ▶ Einsicht in fremde / sensible Daten
 - ▶ Übernahme von Nutzeraccounts



INTERN



WIE WERDE ICH PENTESTER?

Tübix 2026

WIE WERDE ICH PENTESTER?

- ▶ Studium
- ▶ Ausbildung
- ▶ Zertifikate
- ▶ Übung
- ▶ Community
- ▶ Firmensuche



FAQ

- ▶ Kann ich jetzt das Instagram von ihnen hacken?
- ▶ Laufe ich immer mit schwarzem Hoodie und hochgezogener Kapuze herum und meine gesamte Arbeitsoberfläche ist schwarz mit grüner Schrift?
- ▶ Kann ich wie im Film ein Unternehmen in wenigen Minuten von außerhalb hacken?
- ▶ Bin ich paranoid, was Schwachstellen / Phishing angeht?

FRAGEN & DISKUSSION

Emergency Hotline

Ihre Nummer für alle Fälle:
+49 202 31767-112

Wenn Sie einen Sicherheitsvorfall bemerken, zögern Sie nicht.
Kontaktieren Sie unsere Spezialisten, um umgehend Hilfe zu erhalten.

Nico Viakowski

Security Consultant

Hatzfelder Str. 167
D-42281 Wuppertal

Telefon: +49 202 31767-302
E-Mail: n.viakowski@r-tec.net
www.r-tec.net



an **accompio** company